

Integración de monitoreo de redes simulaciones y sistemas

Divier Jácamo Álvarez

Cetav La Libertad

Rol: Analista SOC L1

Fecha: Miércoles 04/03/26

Monitoreo de Eventos de red en simulaciones

Introducción

Las clínicas de salud mental gestionan información clínica sensible, historiales psiquiátricos y registros administrativos que demandan un alto grado de protección la implementación de sistemas de salud electrónicos y plataformas digitales ha aumentado la exposición a amenazas cibernéticas; por lo tanto, las organizaciones de salud necesitan establecer controles de vigilancia constante para detectar y mitigar riesgos en tiempo real.

La supervisión de eventos de red, al ser incorporada en entornos de simulación, permite evaluar la efectividad en la detección, el análisis y la respuesta a incidentes sin poner en peligro la operación real del centro clínico. Desde la perspectiva de un SOC Nivel 1, estas simulaciones sirven como un medio para el entrenamiento y validación de los procedimientos de respuesta ante incidentes.

2. Marco Teórico

Centro de Operaciones de Seguridad (SOC) Nivel 1

El SOC es una organización dedicada a la observación constante de los activos tecnológicos.

El analista del SOC Nivel 1 se encarga de

Supervisar alertas en plataformas SIEM.

Realizar un análisis inicial de eventos de seguridad.

Escalar incidentes de acuerdo con su criticidad.

Registrar y clasificar eventos.

Herramientas como Splunk e IBM QRadar hacen posible la correlación de eventos a partir de firewalls, IDS/IPS y endpoints clínicos.

Monitoreo de Eventos de Red

El monitoreo incluye la recogida, normalización y análisis de registros generados por

Firewalls de perímetro.

Servidores de historias clínicas electrónicas.

Sistemas de autenticación.

Dispositivos médicos conectados.

El marco de ciberseguridad plantea la función como una parte crucial para la capacidad de recuperación organizacional.

Simulaciones en Entornos Sanitarios

Las simulaciones permiten recrear situaciones como:

Ataques de ransomware.

Exfiltración de datos clínicos.

Ataques de denegación de servicio.

Compromiso de credenciales administrativas.

Estas pruebas pueden basarse en metodologías alineadas con la MITRE Corporation mediante el marco MITRE ATT&CK, el cual clasifica tácticas y técnicas de ataque.

3. Metodología de Integración

Diseño del Entorno de Simulación

Se sugiere la creación de un laboratorio aislado que reproduzca la infraestructura tecnológica

de la clínica de salud mental, que incluye:

Servidor de base de datos de pacientes.

Sistema de gestión clínica.

Firewall virtual.

Plataforma SIEM.

Sensores IDS/IPS.

La segmentación de red a través de VLAN permite simular áreas administrativas y clínicas distintas.

Generación de Eventos

La simulación debe producir:

Intentos de acceso no autorizado.

Transferencias masivas de datos.

Escaneos de puertos internos.

Ejecución de malware simulado.

Estos eventos nutren al SIEM, permitiendo al SOC Nivel 1 implementar procedimientos de triage.

Proceso Operativo del SOC Nivel 1

El flujo operativo consiste en:

Recepción de alertas.

Validación del evento.

Análisis de registros correlacionados.

Clasificación.

Escalamiento al SOC Nivel 2 si corresponde.

Documentación de acuerdo con políticas institucionales.

4. Consideraciones Éticas y Regulatorias

Las clínicas de salud mental están sujetas a normativas estrictas de protección de datos que establecen pautas para la confidencialidad y seguridad de la información médica protegida en América Latina; además, las regulaciones locales de protección de datos personales cumplen

una función similar.

Las simulaciones deben asegurar:

El uso de datos anonimizados.

El aislamiento total del entorno de producción.

Un registro formal de las pruebas de seguridad.

Beneficios de la Integración

La implementación del monitoreo en simulaciones proporciona:

Una mejora en la capacidad de detección temprana.

Una disminución del tiempo medio de respuesta

Entrenamiento práctico para el personal del SOC.

Evaluación de brechas en controles de seguridad.

Fortalecimiento de la cultura de ciberseguridad clínica.

Desde el punto de vista de un SOC de Nivel 1, las simulaciones permiten la adquisición de habilidades analíticas en un entorno restringido, reduciendo los riesgos operativos. Además, ayudan a cumplir con normativas internacionales y fomentan el desarrollo del programa de ciberseguridad de la institución.

Una integración efectiva necesita el respaldo del liderazgo clínico, inversión en tecnología y

actualizaciones constantes de las reglas de correlación en el SIEM.

Conclusión

La incorporación del monitoreo de eventos de red en simulaciones en una clínica de salud mental constituye una estrategia clave para potenciar la resiliencia organizacional ante amenazas cibernéticas. Desde el rol de un analista SOC de Nivel 1, estas prácticas no solo mejoran la detección y respuesta ante incidentes, sino que también establecen una cultura de seguridad que se alinea con criterios internacionales la implementación sistemática y ética de estas simulaciones juega un papel crucial en la protección de datos sensibles y en la continuidad operativa de los servicios clínicos.

Análisis de correlación en eventos de red y sistema

1. Introducción

La digitalización en la atención de salud mental ha aumentado la necesidad de depender de tecnologías interconectadas. Esta conexión produce diversas fuentes de eventos: dispositivos de red, servidores clínicos, estaciones de trabajo administrativas y sistemas de autenticación.

El marco indica que la función debe integrar mecanismos avanzados de análisis y correlación para detectar patrones anómalos. En este sentido, la correlación de eventos convierte grandes

volúmenes de datos en inteligencia que puede ser procesada dentro de un Centro de Operaciones de Seguridad.

2. Marco Conceptual

Eventos de Red

Los eventos de red se originan en dispositivos tales como:

Firewalls perimetrales.

Sistemas IDS/IPS.

Switches y routers.

Sistemas de prevención de fuga de datos.

Estos eventos abarcan intentos fallidos de conexión, tráfico anómalo, escaneos de puertos y transferencias masivas de datos.

Eventos de Sistema

Los eventos de sistema se producen en:

Servidores de historia clínica electrónica.

Controladores de dominio.

Equipos médicos conectados.

Estaciones administrativas.

Incluyen registros de autenticación, creación de usuarios, ejecución de procesos y cambios en configuraciones críticas.

Plataforma de Correlación

Las herramientas SIEM como Splunk y IBM QRadar facilitan la integración de logs diversos y la aplicación de reglas de correlación basadas en patrones establecidos. Además, la clasificación de tácticas y técnicas de adversarios puede alinearse con el marco diseñado por MITRE Corporation mediante MITRE ATT&CK.

3. Metodología de Correlación en el Entorno Configurado

Teniendo en cuenta la configuración detallada anteriormente (laboratorio segmentado, servidor clínico, firewall virtual y SIEM centralizado), la metodología de correlación se organiza en las siguientes etapas:

Normalización y Enriquecimiento

Los logs provenientes de la red y del sistema son:

Normalizados a un formato estándar.

Enriquecidos con información de contexto.

Definición de Reglas de Correlación

Las reglas pueden establecer vínculos temporales y lógicos entre eventos, por ejemplo:

Regla 1: Múltiples fallos de autenticación + conexión de IP externa sospechosa = posible
ataque de fuerza bruta.

Regla 2: Transferencia masiva de datos + acceso a base de datos clínica fuera de horario
laboral = posible exfiltración de información.

Regla 3: Escaneo interno de puertos + ejecución de proceso no autorizado en servidor clínico
= posible movimiento lateral.

Análisis Temporal y Contextual

La correlación no se limita a coincidencias inmediatas; también considera:

Ventanas temporales definidas.

Perfil de comportamiento del usuario.

Nivel crítico del activo afectado.

Rol del SOC Nivel 1 en la Correlación

El analista SOC Nivel 1 desempeña funciones cruciales en la interpretación de eventos
correlacionados:

Validación inicial de la alerta generada por el SIEM.

Revisión de logs en bruto para descartar falsos positivos.

Análisis del contexto clínico-administrativo.

Escalamiento documentado al SOC Nivel 2 en caso de un incidente confirmado.

Una correlación adecuada minimiza la fatiga por alertas y mejora el tiempo medio de detección.

Caso de Análisis Aplicado

En un entorno simulado dentro de la clínica de salud mental:

Se genera tráfico inusual desde una estación administrativa.

El firewall detecta comunicación con un dominio considerado malicioso.

Simultáneamente, el servidor clínico registra un inicio de sesión exitoso utilizando credenciales válidas fuera del horario habitual.

La conexión de estos tres acontecimientos sugiere un posible compromiso de las credenciales que previene un intento de exfiltración de datos clínicos, lo que inicia el protocolo de respuesta ante incidentes.

6. Consideraciones Regulatorias

La protección de los datos de los pacientes está sujeta a normativas que requieren controles técnicos y auditorías continuas; la correlación de eventos actúa como un mecanismo fundamental para evidenciar el cumplimiento normativo a través de la trazabilidad y el registro de actividades.

La correlación efectiva entre eventos de red y sistema permite identificar amenazas avanzadas que no se detectarían mediante análisis aislados. En clínicas de salud mental, donde la confidencialidad es crucial, la aplicación de reglas dinámicas y actualizadas es de suma importancia.

La efectividad depende de:

La calidad de los registros.

La constante actualización de firmas y reglas.

La formación continua del personal del SOC.

La integración con inteligencia de amenazas.

Conclusión

El análisis de correlación entre eventos de red y sistema en una clínica de salud mental es un elemento estratégico para la ciberseguridad institucional desde la perspectiva de un SOC Nivel 1, la interpretación adecuada de las alertas correlacionadas mejora la capacidad de detección, disminuye los falsos positivos y refuerza la protección de los datos clínicos sensibles. La alineación con estándares internacionales y marcos de referencia fortalece un enfoque estructurado, medible y sostenible a lo largo del tiempo.

Documentación integración

La acelerada digitalización de los servicios clínicos requiere la implementación de métodos de documentación formal que respalden las estructuras de seguridad establecidas. El marco subraya la importancia de contar con procesos documentados en las funciones de Identificar, Proteger, Detectar, Responder y Recuperar.

En este contexto, la documentación de la integración del monitoreo y correlación no solo refuerza la seguridad, sino que también simplifica las auditorías internas y externas, especialmente en entornos regulados.

Alcance del Documento

Este documento incluirá:

Una infraestructura de red simulada para una clínica de salud mental.

Integración de dispositivos de red y sistemas críticos en el SIEM.

Configuración de reglas de correlación.

Procedimientos operativos del SOC de Nivel 1.

Controles de cumplimiento normativo.

Arquitectura de Integración

Componentes Tecnológicos

La arquitectura desplegada contempla:

Un firewall perimetral virtual.

IDS/IPS para la supervisión interna.

Un servidor de registros clínicos electrónicos.

Un controlador de dominio.

Estaciones administrativas.

Una plataforma SIEM.

Flujo de Integración

Captura de logs: Configuración de envío de registros a través de Syslog seguro.

Normalización: Conversión a un formato estándar.

Enriquecimiento: Vínculo con el inventario de activos y la criticidad clínica.

Almacenamiento seguro: Retención conforme a las políticas institucionales.

Correlación automática: Implementación de reglas estipuladas en el SIEM.

Configuración de Reglas de Correlación

La documentación debe incluir:

El nombre de la regla.

El objetivo para la detección.

Las fuentes de datos implicadas.

Las condiciones lógicas.

La ventana temporal.

El nivel de severidad.

El procedimiento de escalamiento.

Ejemplo Documentado

Nombre: Posible exfiltración de datos clínicos.

Fuentes: Firewall + Servidor clínico.

Condición: Transferencia > 500 MB + acceso fuera del horario laboral.

Ventana: 15 minutos.

Criticidad: Alta.

Acción SOC 1: Validación y escalamiento inmediato.

Procedimiento Operativo Documentado del SOC Nivel 1

La documentación operativa debe incluir:

Recepción de Alerta

Registro automático en el sistema de tickets.

Identificación de un ID único de incidente.

Análisis Inicial

Revisión de las IP de origen/destino.

Validación del usuario implicado.

Confirmación del contexto clínico.

Clasificación

Falso positivo.

Evento informativo.

Incidente de seguridad.

Escalamiento

Notificación al SOC de Nivel 2.

Registro de evidencia digital.

Actualización del bitácora.

Controles de Cumplimiento Normativo

La documentación debe evidenciar la alineación con regulaciones, especialmente en:

Protección de Información Médica Protegida

Control de acceso basado en roles.

Auditoría de accesos y modificaciones.

Conservación segura de logs.

Asimismo, deben establecerse políticas de:

Retención de registros.

Anonimización en entornos de simulación.

Separación entre el entorno productivo y el de laboratorio.

Gestión de Cambios y Mejora Continua

La integración debe incluir una sección de:

Versionado de reglas de correlación.

Evaluación regular de falsos positivos.

Actualización de firmas de IDS/IPS.

Simulaciones controladas trimestrales.

Cada modificación debe ser documentada con:

Fecha.

Responsable.

Justificación técnica.

Evidencia de pruebas realizadas.

Indicadores de Desempeño

La documentación debe contener métricas como:

Tiempo Medio de Detección.

Tiempo Medio de Respuesta.

Tasa de falsos positivos.

Número de incidentes correctamente escalados.

Estos indicadores permiten valorar la madurez operativa del SOC.

La documentación formal de la integración refuerza la trazabilidad, la responsabilidad y la continuidad operativa. En una clínica de salud mental, donde la confidencialidad y la disponibilidad de la información son fundamentales, la falta de documentación puede dar lugar a vulnerabilidades organizacionales y riesgos legales.

Desde la óptica de un SOC Nivel 1, tener procedimientos bien documentados disminuye la incertidumbre en la toma de decisiones y aumenta la uniformidad en la respuesta a incidentes.

9. Conclusión

La documentación de la fusión entre la supervisión de la red, los eventos del sistema y la correlación SIEM en una clínica de salud mental es un elemento clave en la gestión de la ciberseguridad su adecuada organización asegura el cumplimiento normativo, refuerza la

capacidad de detección y optimiza el funcionamiento del SOC. La estandarización de procedimientos, en concordancia con marcos internacionales, crea un entorno seguro y resistente ante amenazas cibernéticas.

Referencias

National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF 2.0)*. National Institute of Standards and Technology.
<https://doi.org/10.6028/NIST.CSWP.29>

MITRE Corporation. (2020). *MITRE ATT&CK®: Design and philosophy* (MP180360R1).
https://attack.mitre.org/docs/ATTACK_Design_and_Philosophy_March_2020.pdf

DivisionCero. (2025). *Correlación de eventos y SIEM*.
<https://docs.divisioncero.com/docs/kudo/politicas/correlacion-eventos-siem>

Rosso, M., Campobasso, M., Gankhuyag, G., & Allodi, L. (2020). *SAIBERSOC: Synthetic attack injection to benchmark and evaluate the performance of Security Operation Centers*. arXiv. <https://arxiv.org/abs/2010.08453>